

Sri Lanka Institute of Information Technology



Enterprise Standards for Information Security - IE3102

Specific Document Tool

IT23269484 – T. H. Ranasinghe

1. Introduction

The ISO 27001 2022 standard is an internationally recognized model for the set-up, implementation, routine maintenance and continuous enhancement of an ISMS. It works only to the extent that clear, standardized and verifiable records have been maintained.

Other document tools convert ISO 27001's requirements into hard evidence for operation: what needs to be recorded, who is responsible, and how information passes through the system from generation to destruction.

This article introduces three key ISMS utilities on which the operation and certification preparedness depends:

1. **Asset Registry** - catalogs and categorizes information assets.
2. **Statement of Applicability (SoA)** - records A control decisions.
3. **Risk Treatment Plan (RTP)** - a plan to reduce risk with specified actions.

These tools cumulatively underpin traceability, accountability and continual improvement as you strive to meet the requirements in ISO 27001 Clauses 4-10 and Annex A.

2. Asset Registry

2.1 Purpose

Clause 8 (Operations) and Annex A (Controls A.5, a.8) state that organizations must have an inventory of information assets in place.

Ownership & Classification the Asset Registry identifies who owns what resources and assigns them to the appropriate security controls across all assets digital, physical, or human.

2.2 Key Functions

- **Accountability** – has a responsible person for every asset.
- **Classification** – Establishes what is sensitive: Public, Internal, Confidential, Restricted.
- **Risk Mapping** – links each asset to threats and associated Annex A controls.
- **Review Cycle** – assures the list remains current with technological and operational changes.

2.3 Template

	A	B	C	D	E	F	G	H	I	J
	Asset ID	Asset Name / Description	Type (Hardware / Software / Data / People)	Owner	Location	Classification	Value (L/M/H)	Associated Risks	Annex A Control Reference	Next Review Date
1										
2	A001	Customer Database	Data	Data Protection Officer	Cloud Server	Confidential	High	Data breach	A.5.30 Access Control Policy	1-Jan-26
3	A002	Finance Server	Hardware	IT Manager	Main Data Centre	Restricted	High	System failure	A.5.29 Backup	1-Jan-26

2.4 Maintenance

- Reviewed at six-month intervals or when there are significant changes.
- Interfaced directly with Risk Register and SoA.
- Old versions are kept for audit purposes.

Result: full transparency over the assets being used and their protection level, allowing this transparency to feed into risk management and control choice.

3. Statement of Applicability (SoA)

3.1 Purpose

The SoA is a regulated document according to Clause 6.1.3 (d). It includes all 93 controls found in Annex A of ISO 27001:2022 and shows these as whether they are applicable to the organization, implemented against them, and the rationale for inclusion or exclusion.

3.2 Importance

- Show that risk treating decisions are systematic and auditable.
- Acts as principal audit body for internal and external accreditation.
- Maintains dynamic inter-locking of risks, controls and business requirements.

3.3 Structure

	A	B	C	D	E	F	G	H
1	Control ID (Annex A)	Control Title	Applicable (Y/N)	Implementation Status	Justification / Rationale	Reference Document / Procedure	Responsible Owner	Last Review
2	A.5.1	Policies for Information Security	Y	Implemented	Defines security objectives and management direction	Information Security Policy	CISO	Jan-25
3	A.5.7	Threat Intelligence	Y	In Progress	Emerging requirement for cyber monitoring	Threat Intel Procedure	SOC Lead	Jan-25
4	A.8.23	Data Leakage Prevention	Y	Implemented	Mitigates high risk from Risk Register	DLP Configuration Guide	IT Security Manager	Jan-25
5	A.8.30	Cloud Services Security	Y	Implemented	Cloud systems host critical data	Cloud Security Policy	ISMS Manager	Jan-25
6	A.7.4	Physical Entry Controls	Y	Implemented	Protects server rooms and secure areas	Visitor Log	Facilities Manager	Jan-25

3.4 Maintenance

- Each year or when someone gets a new super-cool project management tool.
- Shall match RTA and AUDIT Findings properly.
- Formal management justification is necessary for any exclusions.

3.5 Outcomes

- The mapping between the risks and selected controls is clearly identifiable.
- Empirical evidence of the implementation of control according to Annex A.
- Simplified audit and certification process.

4. Risk Treatment Plan (RTP)

4.1 Purpose

The Risk Treatment Plan fits each of the risks identified in the Risk Assessment into how they will be controlled, accepted, insured against or eliminated.

It meets Clause 6.1.3 (a–c) and corresponds to the “Do” part of the PDCA method.

4.2 Template

	A	B	C	D	E	F	G	H	I	J
	Risk ID	Risk Description	Risk Level (L/M/H)	Treatment Option (Avoid / Transfer / Mitigate / Accept)	Relevant Annex A Control	Action Required	Responsible Person	Target Date	Residual Risk Level	Status (Open/Closed)
1										
2	R001	Unauthorized access to customer data	High	Mitigate	A.5.30 Access Control	Implement multi-factor authentication	IT Manager	1-Mar-26	Medium	Open
3	R002	Data loss due to hardware failure	Medium	Transfer	A.5.29 Backup	Procure off-site backup solution	Ops Manager	1-Feb-26	Low	Closed
4	R003	Phishing attack on employees	High	Mitigate	A.6.3 Awareness Training	Conduct quarterly staff training	HR Lead	15-Apr-26	Medium	Open

4.3 Implementation Requirements

- Annex A – Risks control Each risk needs a unique ID and an associated Annex A control.
- Top management needs to assess and take responsibility for residual risks.
- The RTP shall be reviewed quarterly and revised as needed in the event of occurrences or audits.

4.4 Output

RTP supplies working evidence that the company is methodically dealing with all major risks which are discovered from the ISMS scope.

Auditors confirm Risk Register → RTP → SoA are aligned.

5. Document Review and Control

5.1 Purpose

Clause 7.5 of ISO 27001 requires organizations to control all documented information to ensure that it is available, current, and adequately protected.

5.2 Document Control Register Template

	A	B	C	D	E	F	G	H
1	Document Title	Document ID	Version	Owner	Approval Date	Next Review Date	Storage Location	Status (Draft/Approved)
2	Asset Registry	DOC-AR-01	1	ISMS Manager	1-Jan-25	1-Jul-25	SharePoint ISMS Repo	Approved
3	Statement of Applicability	DOC-SOA-01	1.1	Compliance Officer	1-Jan-25	1-Jan-26	ISMS Folder	Approved
4	Risk Treatment Plan	DOC-RTP-01	1.2	Risk Owner	1-Jan-25	1-Apr-25	Secure Drive	Approved

5.3 Review Responsibilities

Document Tool	Responsible Role	Review Frequency
Asset Registry	ISMS Manager	Every 6 months
SoA	Compliance Officer	Annually
Risk Treatment Plan	Risk Owner	Quarterly

Proper document control ensures traceability, prevents outdated records from misuse, and supports continual improvement.

6. Continual Improvement Cycle

6.1 PDCA Mapping

	A	B	C
1	Phase	Activities	Core Documents
2	Plan	Define context and risks	Asset Registry, Risk Register
3	Do	Implement controls	Risk Treatment Plan, SoA
4	Check	Monitor and measure	Internal Audits, Incident Logs
5	Act	Correct and improve	CAPA Records, Management Reviews

6.2 Outcomes

- **Efficiency:** Streamlined, evidence-based processes.
- **Consistency:** Unified templates across departments.
- **Traceability:** Open track between risks and controls.
- **Adaptive:** ISMS evolves via planned updates.

7. Common Implementation Challenges and Solutions

	A	B	C
1	Challenge	Description	Recommended Action
2	Incomplete Asset Identification	Unlisted systems or data sources lead to risk blind spots.	Conduct annual asset discovery and validation workshops.
3	Static SoA Documents	Controls not updated after risk changes.	Integrate SoA review into quarterly management reviews.
4	Poor RTP Tracking	Actions left open without status updates.	Use centralized tracking dashboard with alerts.
5	Documentation Overload	Excessive paperwork slows operations.	Adopt digital templates and version control systems.

8. Benefits of Standardized Tools

	A	B
1	Dimension	Benefits for ISMS Effectiveness
2	Governance and Accountability	Clear roles and ownership for every asset and control.
3	Compliance and Audit Readiness	Provides verifiable evidence for Clause and Annex A requirements.
4	Operational Efficiency	Reduces duplication and manual errors through structured templates.
5	Risk Reduction	Ensures risks are identified and treated systematically.
6	Continual Improvement	Supports data-driven decision-making and review.

9. Conclusion

The Asset Registry, Statement of Applicability and Risk Treatment Plan are critical in demonstrating & maintaining ISO/IEC 27001:2022 compliance. They are the evidence that auditors need to demonstrate due diligence, risk awareness and control effectiveness - but allow management to monitor, measure and continually improve their ISMS.

By standardizing documentation and aligning it strictly with ISO 27001 clauses and Annex A controls, organizations can:

- Demonstrate governance maturity.
- Strengthen information-security posture.
- Ensure sustainable certification and resilience.

These documents are not simply administrative records, but the tangible foundation of the ISMS what turns policy into an implementable and sustainable reality.

10. References

- Aleksandrov, Mark N. and Vasiliev, Victor A. and Aleksandrova, Svetlana V. (2021). Implementation of the Risk-based Approach Methodology in Information Security Management Systems. 2021 International Conference on Quality Management, Transport and Information Security, Information Technologies (IT&QM&IS), (pp. 137-139).
- Guo, Huaqun and Wei, Meng and Huang, Ping and Chekole, Eyasu Getahun. (2021). Enhance Enterprise Security through Implementing ISO/IEC 27001 Standard. 2021 IEEE International Conference on Service Operations and Logistics, and Informatics (SOLI).
- (Third edition 2022-10). ISO/IEC 27001:2022 - Information Security Management Standards, International Organization for Standardization. INTERNATIONAL STANDARD.
- Malatji, Masike. (2023). Management of enterprise cyber security: A review of ISO/IEC 27001:2022. 2023 International Conference On Cyber Management And Engineering (CyMaEn).